

Industrial Security (Bachelor)

Solution Sheet – Section 06 Vulnerabilities and Assessment

Exercise 6.1 – Advisory Analysis (mark scheme)

Award marks for: correct CVE/CWE mapping (2), defensible environmental adjustments (3), realistic mitigation list including non-patch options (3), clear plain-language impact (2).

Exercise 6.2 – Lab Notes

Expected differences:

- Passive captures only protocols actually used; misses silent devices.
- Active scan may discover hidden services (`nmap -sV` reveals banners) but with higher risk of disturbing the PLC.
- OUI lookups (ieee.org or macaddress.io) reveal vendor.

Exercise 6.3 – Mini Risk Register (sample)

Asset	CVE	CVSS-E	Mitigation	Pri	Owner
PLC 12	CVE-25-1001	8.6	FW allowlist; firmware update in maint. window	P1	OT
HMI 03	CVE-25-1002	6.5	AppLocker, KB patch	P2	OT
Historian	CVE-25-1003	9.0	Network isolation; vendor hotfix	P1	IT
Eng laptop	CVE-25-1004	7.0	MDM patch	P2	IT
Jump host	CVE-25-1005	9.1	MFA enforce; immediate patch	P1	IAM

Exercise 6.4 – CVSS Reasoning

With single-host reachability and MFA, modified attack vector drops from Network to Adjacent or Local, modified privileges required becomes High. The score can fall to ~5.5–6.0. Whether that justifies P2 vs P1 depends on *process consequence* – if compromise leads to loss of safety view, treat as P1 regardless.